

Related: [Opportunity brief](#), [event model](#)

This follows the brief's own three parts: Problem Formulation, Solution Definition, Technical Implications.

Assumptions

Written from outside Front, using its public MCP developer documentation (dev.frontapp.com/docs/mcp-server) and the brief, not internal access. The OAuth model, scopes, and rate limits cited throughout are documented publicly, not guessed at. Genuinely unknown from outside: the real volume behind the brief's "growing priority," whether an identity fix is already planned internally, and the extent of Front's internal activity logging beyond what's public.

Part 1: Problem Formulation

Abstract

Front runs the shared inbox where support and sales teams handle every customer conversation, and its Developer Platform bets that inbox becomes somewhere AI agents work too, not just humans. Its MCP server already lets external agents, customer-built copilots, partner integrations, third-party agent frameworks, read Front context and act with real OAuth and scopes. What it doesn't have is an identity for the agent itself: every connection borrows a specific teammate's exact permissions.

That gap surfaces three ways:

- **Customer:** the only lever an admin has is whose OAuth grant an agent rides on, not what the agent itself may do.
- **Partner:** an integration's access ceiling moves with the authorizing teammate's role, and breaks if that person leaves.
- **Third-party client:** needs one access pattern that works identically everywhere it's installed; a model built around one teammate's identity can't give it that.

This PRD proposes a first-class agent connection: an admin-granted principal with its own scopes, its own audit trail, and one-click revocation, with the send step held back for a human in every case. It starts narrow, read and draft only, and earns the case for autonomy later with real usage data.

Industry context

Three trends outside Front make this a now-problem, not a someday one:

- **Scale.** Gartner projects task-specific AI agents in 40% of enterprise apps by 2026, up from under 5% in 2025, and agentic AI in a third of all enterprise software by 2028. MCP itself went from an Anthropic-only spec to Linux Foundation infrastructure backed by OpenAI, Google, and Microsoft within about a year. This isn't an early-adopter request, it's the industry's direction.
- **Identity is the unsolved part.** Recent enterprise surveys put non-human identities, service accounts, API keys, agents, anywhere from 17x to 80x+ human identities, growing roughly 40% a year, most of it ungoverned. Front's agents-borrow-a-teammate's-identity pattern is one fixable instance of that same industry-wide gap.
- **The real risk is skipping the gate, not moving slowly.** Gartner also predicts over 40% of agentic AI projects will be canceled by 2027 over unclear ROI or inadequate risk controls, the exact failure mode a human-gated, audited, revocable connection is built to avoid.

Sources: [Gartner, task-specific agents in enterprise apps by 2026](#); [MCP one-year retrospective](#); [Veza, 2026 State of Identity & Access Report](#); [Gartner, agentic AI project cancellations by 2027](#).

Problem statement

Front's MCP server already supports OAuth 2.1 with real read, write, and send scopes enforced at the tool level. But every connection authenticates as a specific Front teammate and inherits that person's exact permissions; there's no identity for the agent itself, only the identity of whoever authorized it.

That has three consequences:

- An admin can't grant an agent narrower access than that person already has, or manage it as its own object.
- Any activity record shows the authorizing teammate, not the agent, so access drifts with that person's role and breaks if they leave.
- Security and compliance can't assess or revoke an agent's access without touching a human's own OAuth grant.

Every customer asking to connect an agent today either accepts that coupling or waits.

Inputs and data points

What I'd want before committing further, in rough priority order:

- **Actual usage from Front's existing MCP beta:** call volume by tool, which scopes get exercised most, and denial/error rates, real signal on where agents are already pushing against the current impersonation model.
- **The real size of the "growing priority":** request volume and mix behind customer and partner asks to connect agents, not just that it's growing, but by how much and from whom.
- **Security and compliance precedent:** whether Front already manages any non-human identity (service accounts, API keys, internal automations) the same connection/scope/revocation pattern could extend, rather than inventing a new model from scratch.
- **A handful of customer and partner interviews:** what triage, draft, and trigger actually mean in their workflow today, and what breaks when an agent's access is tied to one teammate's OAuth grant.
- **Legal's read on the DPA question:** whether an agent acting under a developer attestation is enough, or each customer's data processing agreement needs individual renegotiation.

Personas

Role	Job to be done	Pain	Success state
Customer (e.g. Instructure)	When conversation volume outgrows headcount, grant an agent access to triage and draft inside my workspace, so I can hold response times without hiring	Can only give an agent access by having it borrow a teammate's identity and exact permissions	Grants an agent its own scoped, named connection; sees what it did; revokes it without engineering help
Partner (e.g. Aircall)	When building a Front integration, get one scope model any admin can grant, so I can ship once instead of adapting per customer	Its integration's access ceiling still depends on which teammate authorized it	Builds once against a stable scope model a customer's admin grants directly
Third-party client (e.g. Claude Desktop)	When a user points me at any Front workspace, connect the same way every time, so I need no bespoke integration per customer	Needs the same access pattern everywhere it's pointed; today's model can't give it that	Connects the same way regardless of which customer's admin grants access

"Admin" and "Support rep" below are roles a Customer's teammates play; "External agent" is the calling client (copilot, partner integration, or third-party client) — Front's system can't tell the three apart at the protocol level, only by which connection grant it holds.

Use cases

Ranked by leverage: impact on Support rep throughput/response time vs. risk and effort to ship safely.

Rank	Use case	Leverage	Notes
1	UC-01: Agent drafts a reply	Highest	High impact, low risk — human still gates every send
2	UC-02: Agent reads conversation context	High	Enabler for every other use case; no write, minimal trust required
3	UC-03: Agent triages a conversation	Medium-high	Compounds at volume; mistakes are recoverable

4	UC-04: Agent triggers a defined workflow	Medium	Narrower applicability; a real action with consequences
---	--	--------	---

- **UC-01** Agent calls `draft_reply` (needs `draft_reply` scope) → draft is created in "drafted" status, visible to the assigned Support rep; never sent.
- **UC-02** Agent calls `get_conversation` (needs `read_conversations` scope) → returns context, no state change; denied and logged if scope missing or connection revoked.
- **UC-03** Agent calls `apply_tags` (needs `apply_tags` scope) → tag/routing applied and logged; denied, no partial application, if scope or tag is invalid.
- **UC-04** Agent calls `trigger_workflow` for one pre-approved workflow ID (needs a scope naming that exact ID) → Front's existing workflow engine runs it as if a human had; any other workflow ID is denied.

Supporting use cases (prerequisites and governance, not independently ranked): UC-05 admin creates a connection with chosen scopes; UC-06 Support rep reviews a draft and issues the send themselves (never the agent); UC-07 admin revokes a connection, denying all subsequent calls immediately; UC-08 admin reviews the audit log, filterable by connection.

The [event model](#) diagrams UC-01, UC-02, and UC-05–UC-08 in full; UC-03/UC-04 follow the identical command/event/read-model pattern and aren't separately diagrammed.

Part 2: Solution Definition

MVP vs. roadmap

MVP: agent connection as its own principal, MCP tools gated by connection scope (read, draft, tag, trigger), a human-gated send, an audit log, one-click revocation.

Beyond GA: v1.1 opt-in autonomous send for pre-approved tags/macros, earning trust incrementally; v2 a directory of vetted partner agents plus per-agent analytics; v2+ expand workflow-trigger from pre-defined workflows to agent-created automation rules.

Release phases

Phase	Duration	Scope	Key risk
P0	1-2 wks	Scope taxonomy, agent-connection data model, security/infra design doc	Security review stalls timeline — loop in legal/compliance from day one
P1	4-6 wks	Connection UI, audit log, 3 MCP tools (read conversation/contact, draft reply); closed beta, 5-10 design partners	Support reps ignore drafts — measure edit-distance/send-rate from day one
P2	3-4 wks	Tag/assign and workflow-trigger tools; open beta, self-serve connections	Overly broad scope grants — default to team/inbox level, rate-limit writes
P3 (GA)	n/a	Decide v1.1 autonomous-send opt-in from beta data	Pressure to fast-follow before trust is earned — gate on measured signals, not a date

Engineering time is short with AI-assisted development. Security review, legal, and design-partner feedback don't compress, so each phase is gated on those, not on build.

Dependencies: security/compliance sign-off on the agent-as-sub-processor question (High risk); Front's core authorization service supporting a new principal type (High); legal review of developer attestation terms (Medium); the existing workflow engine (Medium); design partners for closed beta (Low).

Out of scope and non-goals

Deferred (each has a real trigger to revisit): autonomous send (until draft accept-rate and edit-distance prove out through Phase 2); a partner marketplace/directory (until demand is validated post-GA); a dedicated agent SLA (until usage volume justifies one); SDKs beyond raw MCP calls (until adoption data shows tooling, not trust, is the blocker); multi-workspace connection management (until a multi-workspace customer asks).

Not deferred, ruled out entirely — each would undermine the safety model itself: self-expanding scopes; an agent modifying its own permission grant; cross-workspace or cross-tenant access; any non-MCP transport.

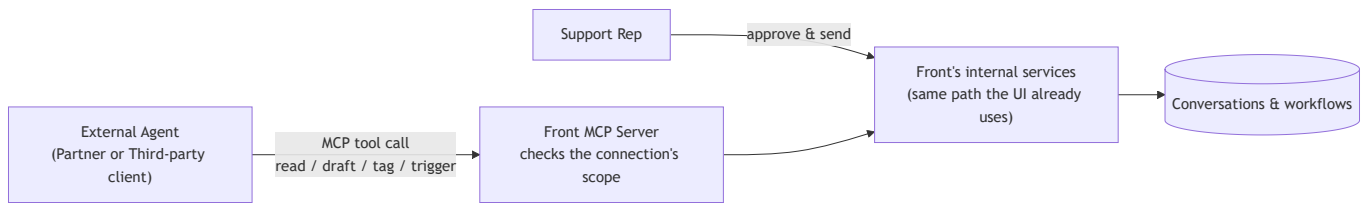
Success metrics

Metric	Target	By when
Adoption	30% of API-plan workspaces create ≥ 1 agent connection	90 days post-GA
Time to first integration	Median under 30 min, credentials to first sandbox call	End of Phase 1 beta
Developer satisfaction	8/10+ on scope-model clarity (post-beta survey)	End of Phase 1 beta
Reliability	99.9% MCP availability; P95 tool-call latency under 500ms	GA

Part 3: Technical Implications

How Front and external systems communicate

MCP is the transport between Front and any external agent. The agent (or its hosting framework) calls typed tools mapping directly to the scoped permission model in Part 1; the MCP server checks the connection's scope, then hands the call to the same internal services Front's UI already uses — no second execution path.



Both paths end at the same internal services, but only the Support rep's path can produce a send — the structural guarantee behind the human-in-the-loop claim in Part 1.

Functional requirements

- **FR-01 Create a scoped agent connection:** admin names a connection and picks scopes from a fixed list; system creates it "active" with exactly those scopes.
- **FR-02 Enforce scope at every tool call:** a call outside the connection's granted scopes is denied and logged, with no partial effect.
- **FR-03 Draft-only tool for agents:** the reply tool only ever produces a draft (`ReplyDrafted` event); no agent path can send to a customer.
- **FR-04 Human-issued send command:** only a Support rep's `SendReply` produces a `ReplySent` event; no connection identity can appear as its sender.
- **FR-05 Audit every scoped action:** each successful scoped call writes one audit entry with connection, action, target, and timestamp.
- **FR-06 One-click revocation:** revoking a connection sets it "revoked" immediately; any later call from it is denied.
- **FR-07 Scoped triage tool:** a connection with `apply_tags` can tag/route a conversation within scope, logged.
- **FR-08 Scoped workflow-trigger tool:** a connection scoped to one workflow ID can trigger it through Front's existing engine; any other ID is denied.

Non-functional requirements

- **Latency:** P95 under 500ms (read), under 800ms (write: draft/tag/trigger).
- **Availability:** 99.9%, Front's standard API SLA; no dedicated agent SLA in v1.
- **Throughput:** per-connection rate limits aligned to existing MCP limits (~120/min light reads, 30/min heavy reads, 20/min writes), not pooled across a workspace.
- **Error rate:** under 0.1% internal errors on well-formed calls; 100% of out-of-scope calls denied — zero tolerance for scope escapes.
- **Security:** short-lived credentials via token exchange; every scope check is server-side; revocation takes effect in under one minute end to end.
- **Compliance:** audit entries retained ≥ 1 year; developers attest to data-handling terms at connection time.

Trade-offs to work through with engineering

1. **Coupling vs. a dedicated gateway** — binding tools directly to internal APIs ships faster but risks breaking a public contract on refactor; a versioned gateway is safer but slower.
2. **Sync vs. async tool calls** — MCP favors synchronous request/response, but a multi-minute workflow trigger needs polling or a long-held connection.
3. **Fine-grained vs. bundled scopes** — least-privilege thinking favors fine-grained scopes; admins find bundles easier to reason about at grant time.
4. **Per-connection vs. per-workspace rate limits** — per-connection is predictable for a developer; per-workspace protects infrastructure better but obscures why one agent's calls get throttled by another's.

Assumptions and constraints

Hardest assumption: that human-in-the-loop draft approval is enough to de-risk launch, and customers won't push to skip it. If they do, the permission/audit layer is already robust enough that v1.1 becomes a scope-and-policy change, not a re-architecture.

Constraints: builds on Front's existing MCP OAuth infrastructure, not a replacement; writes stay on the existing internal command/event pipeline; existing customer DPAs can accommodate an agent under an attestation, not a full renegotiation; MCP's own auth patterns are still stabilizing industry-wide, limiting what gets locked in now versus versioned later.